Rapport d'audit — Fixture

Rapport d'audit

Fixture

Exposition cryptographique et durées de confidentialité · 02/11/2026 21:10 UTC

Sommaire

- Objet et périmètre
- Méthode
- Limites de l'analyse
- Références normatives
- Constatations de fait
- Durées de confidentialité déclarées
- Avis
- Conclusion et recommandations
- Glossaire
- Intégrité du document

1. Objet et périmètre

Commanditaire	[à compléter]
Auditeur	[à compléter]
Organisation	[à compléter]
Référence	[à compléter]
Mission	[à compléter]
Périmètre analysé	tests/fixtures/sample
Date de l'analyse	02/11/2026 21:10 UTC
Volume examiné	3 fichiers lus
Outil	Sablier 0.12.1
Commande exécutée	/sablier/bin/sablier scan tests/fixtures/sample --out=examples/report.html --audit=examples/audit.html --pdf=examples/report.pdf --cbom=examples/cbom.json --calendar=examples/crossings.ics --no-probe --quiet

Ce document est produit par un outil d'analyse. Il rapporte des faits vérifiables et l'avis qui en découle ; il n'emporte aucune qualification juridique, et l'auditeur signataire en demeure l'auteur.

2. Méthode

Lecture statique du dépôt : appels cryptographiques dont l'algorithme est écrit en clair, matériel de clé et certificats présents dans l'arborescence, configuration de serveur et de cadriciel, scripts de déploiement, dépendances déclarées.

Sonde réseau : un handshake TLS ordinaire, identique à celui d'un navigateur, sur les hôtes déclarés. Elle établit ce qui est réellement négocié, que le dépôt peut contredire dans les deux sens.

L'inventaire est ensuite croisé avec la durée pendant laquelle chaque catégorie de donnée doit rester confidentielle. Le raisonnement est celui de l'inégalité de Mosca (2015), simplifié :

année de l'analyse + durée de confidentialité déclarée > péremption de l'algorithme => la donnée déjà émise est exposée, et migrer ne la répare pas

L'analyse est reproductible : la même commande sur le même état du dépôt produit la même empreinte de constatations. L'outil ne prédit pas l'arrivée d'un calculateur quantique ; il utilise l'échéance réglementaire comme date de planification.

3. Limites de l'analyse

Ces limites figurent dans le corps du rapport et non en note de bas de page : un inventaire qui ne dit pas ce qu'il n'a pas regardé n'est pas un inventaire.

- la cryptographie de vos services gérés — base de données, stockage objet, terminaison TLS chez un intermédiaire — n'apparaît dans aucun fichier de ce dépôt
- ce qui est réellement négocié à l'exécution, pour tout hôte non déclaré dans la section « sonde »
- les clés détenues dans un HSM ou chez un fournisseur
- la durée de vie réelle des données : elle vient de votre déclaration, pas du code — un domaine non déclaré est calculé avec une durée par défaut de 3 ans
- L'horizon d'exploitation du système n'est pas déclaré : le calcul suppose qu'il cesse d'écrire des données aujourd'hui. C'est l'hypothèse optimiste — un service encore en production dans dix ans produira dix ans de données de plus à protéger. Ajoutez `service_until` à la déclaration.
- Échéance retenue : 2035, d'après NIST IR 8547. Un autre cadre — institutionnel, défense — donne une autre date : voir `regime` dans la déclaration.
- Les sommes de contrôle (CRC32, Adler-32) ne sont signalées qu'à côté d'un jeton, d'un lien ou d'un secret. Une clé de Luhn ou un modulo écrits à la main ne le sont jamais : rien ne les distingue d'un calcul ordinaire, et un code qui accepte un numéro sur la foi de son chiffre de contrôle n'apparaît pas ici.
- Les fichiers binaires (images, polices, archives) ne sont lus que sur leurs premiers méga-octets, et seulement pour trois signes vérifiables : un bloc de clé, des octets après la fin de l'image, une extension qui ment sur le contenu. Un message dissimulé dans les bits d'une image n'est pas détecté ici, et ne prétend pas l'être.
- Les fichiers YAML de configuration sont lus comme du texte, pas interprétés : un algorithme défini par un paramètre, par un fichier importé ou par une variable d'environnement n'est pas vu ici.
- Les constatations de confiance moyenne sont signalées comme telles : l'algorithme y provient d'une variable ou d'une configuration, et n'a pas pu être établi par la seule lecture.

Ce qu'il a cherché et n'a pas trouvé

Chaque ligne est un résultat, pas un silence : un détecteur a ouvert ces fichiers et n'en a rien tiré. Le nombre est là pour que vous puissiez juger la portée de la phrase plutôt que la croire.

- 3 fichier(s) lu(s) : aucune clé privée, aucun certificat, aucun magasin de clés dans l'arborescence versionnée.

4. Références normatives

La date de péremption retenue est une échéance réglementaire, pas une prédiction de rupture cryptographique.

FIPS 203 / 204 / 205 (2024)	**ML-KEM, ML-DSA et SLH-DSA normalisés (août 2024).**
NIST IR 8547 ipd (2024)	Brouillon public initial, novembre 2024. Table 2 : RSA et ECDSA à 112 bits de sécurité sont dépréciés après 2030 ; RSA, ECDSA et EdDSA sont interdits après 2035, quel que soit le niveau.
CNSA 2.0 (NSA)	Échéances par usage : signature de logiciels et de micrologiciels et équipements réseau en 2030, navigateurs, services en nuage et systèmes d'exploitation en 2033.

Directive (UE) 2022/2555 (NIS 2)	Directive du 14 décembre 2022, JO L 333/80, à transposer « by 17 October 2024 » selon son article 41. Son article 21 §2 h) range parmi les mesures de gestion du risque « policies and procedures regarding the use of cryptography and, where appropriate, encryption ». Son article 34 fixe ce que la loi de chaque État membre doit au minimum permettre : pour une entité essentielle, un plafond d'au moins 10 000 000 € ou 2 % du chiffre d'affaires mondial annuel, le plus élevé des deux ; pour une entité importante, 7 000 000 € ou 1,4 %. C'est un plancher sur le plafond et non une limite — une loi nationale peut aller au-delà, et plusieurs ajoutent leurs propres sanctions pour des manquements précis. Dans l'Union, c'est l'obligation à laquelle cet inventaire répond, et elle vaut dans les vingt-sept États membres indépendamment de l'avancement de chaque transposition. Pour une entité hors de l'Union, cette ligne est un repère et non une obligation : le cadre retenu est celui que désigne `regime` dans la déclaration. Ce document est un inventaire cryptographique, pas un rapport de conformité NIS 2 : il ne dit rien de l'enregistrement auprès de l'autorité ni de la déclaration des incidents.
Recommandation (UE) 2024/1101	Recommandation du 11 avril 2024 : feuilles de route nationales coordonnées, publiées sous deux ans, et schémas hybrides.
UE — feuille de route NIS CG (23/06/2025)	Feuille de route coordonnée du groupe de coopération NIS, 23 juin 2025. Classe les cas d'usage par la confidentialité due : haut risque si une compromission après dix ans ou plus causerait encore un dommage significatif. La cryptographie à clé publique vulnérable au quantique ne doit plus être employée seule après fin 2030 pour le haut risque, après fin 2035 pour le risque moyen. L'inventaire cryptographique figure parmi les First Steps attendus au 31/12/2026, et le format CBOM y est recommandé.
ANSSI — avis sur la migration post-quantique	Hybridation jugée essentielle partout où le post-quantique est déployé, et exigée pour les visas de sécurité français. Après 2030, l'ANSSI estime qu'il ne sera plus raisonnable d'acquérir un produit sans post-quantique.
Cadre national — non déclaré	Aucune juridiction déclarée, et elle n'est pas déduite de la langue de ce document : une langue n'est pas un pays. Ajoutez `jurisdiction` à la déclaration, en code à deux lettres, pour que ce document cite la transposition qui vous auditera.

Échéance retenue pour ce rapport : 2035. Échéances vérifiées auprès de leurs sources le 30/09/2026.

5. Constatations de fait

Chaque ligne est une observation directe, numérotée pour pouvoir être citée. Elle n'emporte aucun jugement : l'avis figure en section 7.

N°	Élément relevé	Emplacement	Élément observé	Confiance
1	AES-256	deploy/backup.sh:4	pg_dump -Fc app | openssl enc -aes-256-cbc -pbkdf2 -pass env:BACKUP_KEY > dump.enc	haute

2	RSA	deploy/backup.sh:3	openssl genrsa -out /etc/backup/key.pem 2048	haute
3	RSA	deploy/backup.sh:5	ssh-keygen -t rsa -b 4096 -f /root/.ssh/offsite	haute
4	AES-256	src/Tokens.php:22	return openssl_encrypt($plain, 'aes-256-gcm', $key, 0, random_bytes(12));	haute
5	MD5	src/Tokens.php:12	return md5($url); // cache key: not a security control	haute
6	SHA-1	src/Tokens.php:17	return sha1($payload);	haute
7	RSA	src/Tokens.php:7	return jwt_encode($claims, $this->key, 'RS256');	haute

6. Durées de confidentialité déclarées

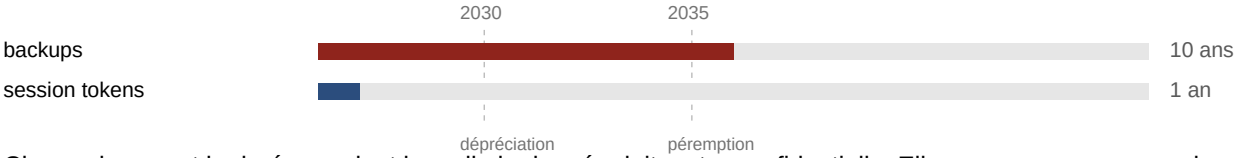
Ces durées sont une donnée d'entrée fournie par le commanditaire. L'outil ne peut ni les vérifier ni les déduire du code : tout l'avis de la section 7 en dépend, et une durée corrigée change le verdict.

Domaine	Durée	Chemins	Justification fournie	Déclarée par
backups	10	deploy/backup.sh, deploy/*backup*	Holds the whole database, including ten years of accounting records.	auteur et date inconnus
session tokens	1	src/Tokens.php		auteur et date inconnus

Durée appliquée aux domaines non déclarés : 3 ans.

Cette déclaration n'est pas signée. Les durées ci-dessus engagent qui les a écrites, et rien ne prouve ici qui c'était : sablier endorse <déclaration>.

Durée de confidentialité des données, face à la péremption des algorithmes



Chaque barre est la durée pendant laquelle la donnée doit rester confidentielle. Elle passe en rouge quand un algorithme récoltable la protège au-delà du trait de péremption — dépasser le trait sans être rouge signifie que la donnée dure longtemps, mais qu'elle est protégée par de la cryptographie qui tiendra.

Dates de bascule

- backups — 10 ans — bascule franchie depuis 2026

Une donnée chiffrée l'année Y reste sensible jusqu'à Y + sa durée. L'année de bascule est donc celle à partir de laquelle tout ce qui est chiffré survit à la péremption de 2035 : avant, le domaine tient ; à partir d'elle, ce qui est émis est déjà perdu le jour où l'algorithme tombe.

7. Avis

L'avis découle des constatations de la section 5 et des durées de la section 6. Il distingue ce qui se récolte — le chiffrement, qu'un adversaire peut capturer aujourd'hui pour le déchiffrer plus tard — de ce qui ne se récolte pas, les signatures.

COMPROMIS

Chiffré aujourd'hui, à garder confidentiel jusqu'en 2036 — soit 1 an après la péremption de RSA. Une capture faite maintenant sera lisible.

Constatations concernées : n°2

Remplacement ML-KEM (chiffrement) ou ML-DSA (signature), en hybride pendant la transition

CASSÉ AUJOURD'HUI

Cassé classiquement, indépendamment du quantique. L'échéance était hier.

Constatations concernées : n°6

Défauts publiés, vérifiables auprès du NIST : CVE-2005-4900

Remplacement SHA-256

SURVEILLER

Signature : pas de récolte possible. À migrer avant 2030 pour la conformité, sans urgence de confidentialité.

Constatations concernées : n°3, n°7

CONFORME

Tient face à Grover. Rien à faire.

Constatations concernées : n°1, n°4

PROBABLEMENT HORS SUJET

Ressemble à un identifiant (clé de cache, empreinte) plutôt qu'à un contrôle de sécurité. À confirmer, pas à corriger.

Constatations concernées : n°5

8. Conclusion et recommandations

- Décider du sort des données déjà émisesC'est la décision que personne ne prend, et elle vient avant la migration. Les domaines concernés (backups) sont protégés par un algorithme qui ne tiendra pas jusqu'au bout de leur durée de confidentialité : ce qui a déjà été chiffré et transmis est hors de portée d'un correctif. Trois issues, et il faut en choisir une explicitement — re-chiffrer le stock existant avec un algorithme qui tient, faire tourner les clés et réémettre ce qui peut l'être, ou acter par écrit qu'on accepte le risque sur les données antérieures à 2035. Migrer sans trancher cette question protège les données futures et laisse les anciennes exposées sans que personne ne l'ait décidé.
- Remplacer ce qui est déjà cassé Un usage repose sur un algorithme cassé classiquement. Aucun raisonnement quantique n'est nécessaire : l'échéance était il y a dix ans, le remplacement est connu et ne demande pas un projet. À traiter avant tout ce qui concerne la transition post-quantique, parce que c'est moins cher et déjà exploitable.
- Remettre ce rapport au calendrierLa fenêtre se referme d'elle-même : la date de péremption ne bouge pas (2035), mais chaque année qui passe rapproche vos données de cette ligne. Un domaine conforme aujourd'hui avec une durée de neuf ans ne le sera plus l'an prochain. Rejouer l'analyse une fois par an suffit — et vérifier à cette occasion que l'échéance réglementaire n'a pas bougé.

9. Glossaire

Les sept termes nécessaires à la lecture du présent rapport.

Récolte différée	Capturer aujourd'hui des données chiffrées pour les déchiffrer lorsque la machine capable de le faire existera. Pour ces données, la date de compromission est le jour du chiffrement, pas celui de l'attaque.
Confidentialité	Ce que protège le chiffrement : la donnée reste illisible. C'est la seule propriété exposée à la récolte différée.
Authenticité	Ce que protège une signature : l'origine est établie. Une signature ne se capture pas pour être forgée plus tard ; l'urgence ne porte que sur les ancres de confiance à longue durée.
Durée de confidentialité	Nombre d'années pendant lesquelles une catégorie de donnée doit rester secrète. Elle est déclarée par le commanditaire ; aucun outil ne peut la déduire du code.
Péremption	Année à partir de laquelle un algorithme ne doit plus protéger de donnée confidentielle. Retenue ici d'après les textes cités en section 4.
Symétrique / asymétrique	La cryptographie symétrique (AES, ChaCha20) n'est pas le sujet : un calculateur quantique en réduit la marge sans la casser. Le problème porte sur l'asymétrique : RSA, courbes elliptiques, échange de clés.
Hybridation	Combiner un algorithme classique et un algorithme post-quantique, de sorte que la protection tienne si l'un des deux tombe. C'est la position des autorités pendant la transition.

10. Intégrité du document

L'empreinte porte sur les constatations et non sur ce fichier : deux rendus du même inventaire, dans deux langues, donnent la même valeur.

empreinte des constats	92cd7996cbe685ae50aae64e425865da36bd3c25b0ac6341ca1668dfd1e5431d

Ce rapport n'est pas signé. Pour qu'un tiers puisse établir qu'il n'a pas été modifié depuis son émission, relancer l'analyse avec l'option de signature.

Déclaration de l'auditeur

Aucune déclaration de l'auditeur n'a été fournie. Elle doit être rédigée, datée et signée avant que ce document soit produit devant un tiers.